Saudi GRC Platform

Automation Rules

Source: `automation-rules.md`

10 — Automation and Business Rules

Cross-module automation rules. Each rule is a service-layer hook (`@TransactionalEventListener` or direct invocation) that fires after a state change. Every rule writes an audit event.

#	Rule	Trigger	Conditions	Action	Created records	Notifications	Escalation	Exceptions	Audit
1	Cyber incident → PDPL breach	CyberIncident.transition(NOTIFIED) or asset has pii=true	impacted asset flagged as PII	call CyberPdplBridgeService.triggerForIncident() — creates DataBreach + starts 72h timer + logs to cyber_breach_bridge_log	DataBreach, BridgeEvent	DPO + CISO email + dashboard	Hour-48 to CISO; hour-60 to DPO	BREACH_SKIPPED if breach already exists	bridge_log + audit.events
2	System with personal data → PIA	new cyber.cyber_assets row with pii=true	pii=true AND classification IN (CONFIDENTIAL, RESTRICTED)	create Dpia DRAFT + notify DPO	Dpia	DPO	Day-7 if not started	none	dpia.events
3	Critical system → BIA + DRP + NCA assessment	new asset with classification=CRITICAL	criticality CRITICAL	create BIA stub + DRP stub + NCA-CCC control-assessment stub	BiaRecord, DrPlan, ControlAssessment	BCM Mgr + DR Owner + CISO	per-record SLA	system asset already covered → skip	per-stub events
4	Supplier processes personal data → processor DD	new Vendor with data_processor=true	new vendor; processor flag set	create ProcessorAssessment IN_PROGRESS	ProcessorAssessment	DPO	day-14 if not started	none	processor.events
5	Cloud service supports critical → CCC + supplier resilience + DRP review	new cloud-vendor or new critical-service link	service is critical AND vendor is cloud	create NCA-CCC assessment + AlternateSupplier stub + DRP review	ControlAssessment, AlternateSupplier, DrPlan-review	CISO + Vendor Risk Mgr	day-30	none	cloud.bootstrap

#	Rule	Trigger	Conditions	Action	Created records	Notifications	Escalation	Exceptions	Audit
6	Risk exceeds appetite → escalate to committee	Risk.residualScore > appetiteBand.ceiling	residual > ceiling	mark risk ABOVE_APPETITE; add to AppetiteBreachFeed; auto-schedule next risk-committee agenda item	AppetiteBreachEvent + CommitteeAgendaItem	Risk Committee	Daily until accepted/mitigated	accepted risks excluded	breach event + audit
7	BIA RTO < current recovery capability → gap + CAPA	BiaRecord.rto < DrPlan.rto_actual	gap > 0	open CAPA originType=bia_gap severity HIGH; mark BIA GAP_IDENTIFIED	CapaTask	BIA Owner + DR Owner	day-7 if owner not assigned	accepted gaps with active risk acceptance	bia.gap
8	Supplier has no valid BCP → CAPA	vendor has no evidence_links with type=BCP newer than 12 months	criticality HIGH or CRITICAL	open CAPA originType=supplier_bcp_missing severity HIGH	CapaTask	Vendor Risk Mgr	day-14 if not actioned	grace for new vendors (90d)	scm.evidence
9	NCA evidence expires → notify evidence owner + control owner	evidence expiry_date <= today + 30d	scheduled job	mark EXPIRING_SOON; email both owners	EvidenceNotification	Evidence Owner + Control Owner	7d before expiry; expiry day; +7 to CISO	none	evidence.expiry
10	DSR breaches SLA → escalate to Privacy Mgr	DataSubjectRequest.status != FULFILLED AND received_at + 30d - now < 2d	open DSR	escalate to Privacy Mgr + auto-add to DPO daily digest	EscalationEvent	DPO + Privacy Mgr + Compliance	day-23 (DPO), day-28 (Privacy Mgr), day-30 (Compliance)	DSR marked complex with extension	dsr.escalation
11	Risk acceptance expires → reopen risk review	RiskAcceptance.expiry_date <= today	active acceptance	flip risk to EXPIRED review; create review task; notify Risk Owner + CRO	Task	Risk Owner + CRO	7d to re-decide	none	risk.acceptance.expiry

#	Rule	Trigger	Conditions	Action	Created records	Notifications	Escalation	Exceptions	Audit
12	Fourth-party concentration HIGH → CAPA (NEW — TprmAutomationService)	FourthPartyExposure.concentration_risk newly = HIGH	rising edge only	open CAPA originType=fourth_party_exposure severity HIGH	CapaTask	Vendor Risk Mgr	day-30 target	none	tprm.automation
13	Processor DD FAIL → CAPA (NEW)	ProcessorAssessment.overall_outcome = FAIL AND status=COMPLETED	overall outcome FAIL	open CAPA originType=processor_assessment severity CRITICAL	CapaTask	DPO + CISO	day-45 target	none	tprm.automation
14	Resilience test FAIL → CAPA (NEW)	SupplierResilienceTest.outcome = FAIL AND status=COMPLETED	FAIL outcome	open CAPA originType=supplier_resilience_test severity HIGH	CapaTask	Vendor Risk Mgr + BCM	day-60 target	none	tprm.automation
15	RCA APPROVED → spawn CAPAs	RootCauseAnalysis.status = APPROVED	recommendations text parsed	parse numbered list; create one CAPA per recommendation; append CAPA IDs back to RCA capa_refs	N × CapaTask	RCA owner	per CAPA SLA	none	rca.capa.gen
16	Evidence chain BROKEN → alert	EvidenceChainVerifyService finds break	scheduled or on-demand	mark item chain_status=BROKEN; notify Evidence Owner + Auditor	ChainBreakEvent	Evidence Owner + Compliance	next business day	manual override with sign-off	evidence.chain.break
17	Vendor exit-plan rehearsal FAIL → CAPA + DRP re-test	ExitPlan.recordTest(outcome=FAIL)	FAIL outcome	open CAPA; schedule DR retest within 90d	CapaTask + DRP TestSchedule	COO + BCM Mgr	day-90	none	scm.exit.fail

#	Rule	Trigger	Conditions	Action	Created records	Notifications	Escalation	Exceptions	Audit
18	KRI threshold breached → KRI breach event + escalate	KRI value crosses threshold	value > threshold	record KriBreachEvent; notify Risk Owner; escalate at +14d if unresolved	KriBreachEvent	Risk Owner	day-7 RM; day-14 Risk Committee	none	kri.breach
19	Policy expires → renew workflow	Policy.effective_to - today <= 30d	scheduled	start renewal workflow; assign to policy owner	Renewal Task	Policy Owner	day-7 escalate to Compliance	none	policy.renewal
20	Cross-border transfer expires → reassess	CrossBorderTransfer.expiry_date <= today + 30d	scheduled	flip to REVIEW_DUE; notify DPO	ReviewTask	DPO	day-30	none	cbt.review
21	Vulnerability critical 30d overdue → CAPA	Vulnerability.severity=CRITICAL AND created_at + 30d < now	overdue	open CAPA + alert CISO	CapaTask	Vuln Mgr + CISO	daily	accepted exceptions	vuln.overdue
22	Board-pack signed → distribute	DigitalSignatureTransaction.status=SIGNED AND purpose contains BOARD_PACK	chairman signed	distribute pack to board members + audit committee	DistributionEvent	Board members	n/a	none	reporting.board.dist
23	Workflow promote to ACTIVE → version snapshot	WorkflowVersion.status=DRAFT → ACTIVE	version promote	snapshot prior ACTIVE → DEPRECATED; broadcast to in-flight workflows	WorkflowVersion	Workflow users	n/a	none	workflow.promote
24	Tenant white-label change → realtime broadcast	Organisation.branding_json update	new branding	realtime push to all sessions for that tenant	broadcast event	tenant users	n/a	none	branding.update

#	Rule	Trigger	Conditions	Action	Created records	Notifications	Escalation	Exceptions	Audit
25	Suspicious login → MFA challenge	login from new IP/UA combination	risk score > threshold	force MFA before allowing session	AuthChallenge	user	block after 3 fails	none	auth.suspicious
26	Failed Art. 28 control C5 (breach notification) → open bridge config	ProcessorAssessment.c5_breach_notification=FAIL	C5 fail	flag bridge-config gap on the related vendor	Gap flag	DPO	day-14	none	bridge.config.gap
27	Crisis declared → invocation of related BCPs	CrisisEvent.declare()	severity ≥ SEV2	auto-invoke BCPs for affected services	Invocation × N	service owners	hour-1	none	crisis.invoke
28	Lessons-learned approved → propagate	Lessons Learned. status=APPROVED	per source	distribute to relevant BIAs + DRPs + risk register; create tasks for material changes	LinkedTasks	owners	per task	none	lessons.dispatch

Notification routing

Every rule's notifications go through `notification.outbox` and respect the recipient's channel preferences (`notification.channels`): EMAIL, SMS, WEBHOOK, MS Teams. Dashboard surfaces always update via realtime broadcaster `changed.{entity}`.

Exceptions / suppression

- A rule fires only on a rising-edge state change (no infinite loops).
- An admin can suppress a rule per-record via the `automation.suppressions` table (audit-logged).
- The `BREAK_GLASS` permission bypasses suppression checks for a single manual action.